

Mapeo de preguntas a requisitos normativos y marcos de referencia

La siguiente tabla relaciona cada pregunta de la encuesta con los principales marcos normativos y de buenas prácticas a los que contribuye. No pretende ser exhaustiva al nivel de subcontroles, pero sí ofrecer una guía clara de alineamiento.

Abreviaturas de referencia (no exhaustivas):

- ISO 27001 – Controles de seguridad de la información.
- ISO 27002 – Guía de implementación de controles.
- ISO 27005 – Gestión de riesgos.
- NIST CSF – NIST Cybersecurity Framework.
- ENS – Esquema Nacional de Seguridad (España).
- NIS2 – Directiva (UE) sobre ciberseguridad.
- CISA BOD 22-01 – Directiva sobre KEV para agencias federales EE. UU.

ID Pregunta	Bloque	Tema principal	Referencias normativas/marcos	Comentario de alineamiento
PERF-01	PERF	Tipo de organización	ISO 27001 contexto; NIS2 ámbito	Ayuda a contextualizar la aplicabilidad de requisitos y el nivel de criticidad esperado.
PERF-02	PERF	Tamaño	ISO 27001 contexto; ENS alcance	Permite ajustar expectativas de madurez y escalabilidad de controles.
PERF-03	PERF	Sector	NIS2 Art. 3-4; ENS ámbitos	Relaciona la organización con sectores esenciales/importantes y obligaciones específicas.
PERF-04	PERF	Ámbito geográfico	NIS2; RGPD; legislación local	Contextualiza la exposición regulatoria y la necesidad de armonización multinivel.
GOV-01	GOV	Política de gestión de vulnerabilidades y KEV	ISO 27001 A.5, A.8; ISO 27002 8.8; NIST CSF ID.RA, PR.IP; ENS MP.INFO	Exige política formal de gestión de vulnerabilidades, incluyendo KEV como fuente prioritaria.
GOV-02	GOV	Roles y responsabilidades sobre KEV	ISO 27001 A.5.2; NIST CSF GV; ENS ORG.1	Fomenta la definición clara de responsabilidades y gobierno sobre vulnerabilidades.
GOV-03	GOV	Integración de KEV en gestión de riesgos	ISO 27005; ISO 27001 A.5, A.8; NIST CSF ID.RA	Alinea KEV con procesos formales de gestión de riesgos de ciberseguridad y corporativos.

GOV-04	GOV	Frecuencia de revisión KEV	CISA BOD 22-01; NIST CSF DE.CM; ENS OP.2	Refuerza la monitorización continua de amenazas y vulnerabilidades explotadas.
GOV-05	GOV	Criterios de priorización (CVSS/EPSS/KEV)	ISO 27002 8.8; NIST CSF PR.IP; NIST SP 800-40	Establece bases para priorización basada en riesgo efectivo y explotación conocida.
GOV-06	GOV	SLAs de remediación para KEV	CISA BOD 22-01; NIST CSF RS.MI; ENS MP.SI	Conecta plazos de remediación con obligaciones operativas y de gestión de incidentes.
VUL-01	VUL	Inventario de activos	ISO 27001 A.5, A.8; NIST CSF ID.AM; ENS MP.SI	Inventario como prerequisite para gestión eficaz de vulnerabilidades y KEV.
VUL-02	VUL	Escaneo y etiquetado KEV	ISO 27002 8.8; NIST CSF PR.IP, DE.CM; CISA KEV	Asegura el uso de herramientas que distinguan vulnerabilidades explotadas.
VUL-03	VUL	Correlación KEV-activos	NIST CSF ID.AM, PR.IP; ISO 27002 8.8	Mide la capacidad de vincular amenazas concretas con activos específicos.
VUL-04	VUL	Medición de tiempos de remediación	NIST CSF PR.IP, RS.MI; ENS seguimiento	Enfocado en métricas de tiempo de respuesta y mejora continua.
VUL-05	VUL	Cumplimiento de plazos de remediación	CISA BOD 22-01; NIS2 Art. 21; NIST CSF	Relaciona la práctica con plazos mandatorios o recomendados para explotación conocida.

VUL-06	VUL	Tratamiento de dispositivos perimetrales	ISO 27001 A.8, A.10; NIST CSF PR.AC, PR.PT; ENS MP.COM	Foco en hardening y gestión prioritaria de perímetro y dispositivos expuestos.
VUL-07	VUL	Gestión de sistemas legacy	ISO 27002 ciclo de vida; NIST CSF ID.AM, PR.IP; ENS MP.SI	Promueve la gestión de tecnologías obsoletas y su riesgo asociado.
PEN-01	PEN	Frecuencia de pentests	ISO 27001 A.8.8; NIST CSF PR.IP, DE.CM; ENS pruebas	Conecta la realización periódica de pruebas de seguridad con buenas prácticas.
PEN-02	PEN	Cobertura KEV en pentests	NIST CSF PR.IP, DE.CM; CISA KEV	Asegura que los escenarios de prueba reflejan explotación real constatada.
PEN-03	PEN	Gestión de hallazgos de pentest	ISO 27001 A.8.8, A.10; NIST CSF RS.MI; ENS MEJ	Integra hallazgos en procesos de remediación y mejora continua.
PEN-04	PEN	Ejercicios Red/Purple Team	NIST CSF DE.CM, RS.IM; ENS OP.2	Refuerza la simulación de ataques avanzados y ejercicios de respuesta.
PEN-05	PEN	Verificación del cierre de KEV	ISO 27002 8.8; NIST CSF RS.MI	Comprueba la eficacia de las medidas de remediación implementadas.
SIEM-01	SIEM	Existencia de SIEM/SOC	NIST CSF DE.CM, RS.AN; ENS OP.2	Evalúa la capacidad organizativa para monitorizar y responder a eventos de seguridad.

SIEM-02	SIEM	Casos de uso para explotación de vulnerabilidades	NIST CSF DE.CM, PR.PT; CISA KEV	Enlace directo entre inteligencia de amenazas y casos de uso de detección.
SIEM-03	SIEM	Fuentes de logs y visibilidad	ISO 27001 A.8, A.12; NIST CSF DE.CM; ENS MP.SI	Mide la cobertura de monitorización y registro de eventos relevantes.
SIEM-04	SIEM	Integración de inteligencia de amenazas	NIST CSF DE.CM, ID.RA; NIS2 Art. 21	Evalúa la capacidad de consumir y aplicar inteligencia de amenazas (incluidas KEV).
SIEM-05	SIEM	Detección basada en comportamiento	NIST CSF DE.CM; ISO 27002 monitorización	Fomenta el uso de capacidades avanzadas (EDR/NDR/UEBA) para detectar explotación.
SIEM-06	SIEM	Medición de MTTD en incidentes	NIST CSF DE.CM, RS.MI; ENS indicadores	Integra métricas operativas clave para la mejora de la detección.
AWR-01	AWR	Formación general en seguridad	ISO 27001 A.6; ISO 27002 concienciación; NIST CSF PR.AT; ENS ORG.4	Refuerza la concienciación y formación del personal.
AWR-02	AWR	Formación técnica específica en vulnerabilidades/ KEV	ISO 27001 A.7; NIST CSF PR.AT; NIS2 Art. 20	Aborda la capacitación de perfiles técnicos críticos para gestión de vulnerabilidades.
AWR-03	AWR	Simulaciones y ejercicios de concienciación	NIST CSF PR.AT; ENS concienciación	Fomenta el uso de ejercicios prácticos (phishing simulado, etc.).

AWR-04	AWR	Cultura de reporte de incidentes	ISO 27035; NIST CSF RS.CO; ENS OP.4	Evalúa la madurez cultural para comunicar incidentes y sospechas.
AWR-05	AWR	Medición de eficacia de la formación	ISO 27001 A.6; NIST CSF ME; ENS seguimiento	Conecta la formación con métricas de resultado y mejora.
MET-01	MET	Indicadores sobre vulnerabilidades y KEV	NIST CSF ME; ISO 27004; ENS indicadores	Enfocado en la definición y seguimiento de métricas clave.
MET-02	MET	Indicadores sobre pentesting y SIEM	NIST CSF ME; ISO 27004; ENS MEJ	Fomenta la medición del rendimiento de controles técnicos y procesos.
MET-03	MET	Uso de benchmarks externos	NIST CSF ID.RA, ME; ENISA informes	Incentiva la comparación con referencias sectoriales y buenas prácticas.
MET-04	MET	Cálculo de ROI en seguridad	ISO 27005 (análisis de riesgo); NIST CSF GV; NIS2 gobierno	Introduce lógica de coste/beneficio en decisiones de seguridad.
MET-05	MET	Madurez percibida en vulnerabilidades/ KEV	ISO 27004; NIST CSF ME	Permite captar el autodiagnóstico de madurez como complemento a indicadores objetivos.
IMP-01	IMP	Existencia de plan de mejora	ISO 27001 A.10; NIST CSF IM; ENS MEJ	Evalúa la presencia de un programa estructurado de mejora continua.
IMP-02	IMP	Obstáculos percibidos	NIST CSF GV, RS; gestión del cambio	Ayuda a identificar barreras para la implantación efectiva de controles.

IMP-03	IMP	Comentarios abiertos	–	Espacio libre para matizar, proponer y contextualizar, útil como insumo cualitativo.
---------------	------------	---------------------------------	---	---

Este mapeo puede adaptarse y ampliarse con referencias más finas (por ejemplo, citando controles concretos de anexos ISO o medidas específicas del ENS) según el nivel de detalle requerido en cada organización o sector. Lo importante es que sirva de guía práctica para justificar la relevancia de cada pregunta y conectar el diagnóstico con las obligaciones normativas y las buenas prácticas internacionales.